

ABC Healthcare Services

ACCESS CONTROL POLICY

Information Security Governance Program

Field	Details
Document ID	ACP-001
Version	1.0
Classification	Internal
Policy Owner	Information Security Manager
Approved By	Executive Management
Effective Date	June 1, 2026
Review Date	June 1, 2027

Document Revision History

Version	Date	Description	Author
1.0	June 1, 2026	Initial Release	Information Security Manager

1. Purpose

The purpose of this Access Control Policy is to establish requirements for granting, modifying, reviewing, and revoking access to organizational systems, applications, networks, and information assets. Appropriate access control ensures that only authorized individuals have access to information required to perform their job responsibilities while protecting organizational assets from unauthorized disclosure, modification, or destruction.

Risk Statement

Failure to implement effective access controls may result in unauthorized access, data breaches, insider threats, regulatory violations, financial loss, and reputational damage.

2. Scope

This policy applies to all employees, contractors, consultants, vendors, third-party service providers, temporary personnel, and authorized users who access ABC Healthcare Services information systems. This policy applies to all applications, databases, servers, network devices, cloud services, and information assets owned or managed by the organization.

3. Policy Objectives

- Protect organizational information assets.
- Prevent unauthorized access.
- Implement the Principle of Least Privilege.
- Support Role-Based Access Control (RBAC).
- Ensure accountability for user activities.
- Support compliance and audit requirements.
- Strengthen identity and access management controls.

4. Access Control Principles

4.1 Principle of Least Privilege

Users shall be granted the minimum level of access necessary to perform their assigned job responsibilities. Access to permissions shall be limited to business requirements and reviewed regularly.

4.2 Need-to-Know Principle

Access to sensitive information shall only be granted to individuals with a legitimate business need.

Access shall be removed when no longer required.

4.3 Role-Based Access Control (RBAC)

Access shall be assigned according to approved job roles.

Example Access Matrix

Role	Access Level
HR Manager	Employee Records
Finance Manager	Financial Systems
IT Administrator	Infrastructure Management
Customer Support	Customer Service Applications
Executive Management	Executive Reporting Systems

5. User Access Provisioning

All access requests must follow a formal approval process.

Access Provisioning Process

Access Request
↓
Manager Approval
↓
Security Review
↓
IT Provisioning
↓
User Verification

Required Documentation:

- Business justification
- Manager approval
- Requested access level
- System owner approval

6. Access Modification

Access rights shall be modified whenever:

- Job responsibilities change.
- Employees transfer departments.
- Temporary access has expired.
- Business requirements change.

All modifications must follow the same approval process as new access requests.

7. Access Revocation

Access shall be revoked immediately when:

- Employment is terminated.
- Contractor agreements expire.
- Vendor contracts end.
- Unauthorized activities are detected.

Revocation Targets

User Type	Removal Timeline
Employee Termination	Within 24 Hours
Contractor Completion	Immediate
Vendor Offboarding	Immediate
Temporary Access	Automatic Expiration

8. Privileged Access Management

Privileged accounts require additional security controls due to elevated permissions.

Requirements include:

- Separate administrator accounts.
- Multi-Factor Authentication (MFA).
- Quarterly access reviews.
- Activity logging and monitoring.
- Management approval.
- Documented business justification.

Examples of Privileged Accounts

- System Administrators
- Database Administrators
- Cloud Administrators
- Security Administrators

9. Access Reviews

User access reviews shall be conducted regularly to ensure permissions remain appropriate.

Review Schedule

Review Type	Frequency
User Access Review	Quarterly
Privileged Access Review	Quarterly
Service Account Review	Semi-Annual
Vendor Access Review	Quarterly

Review Requirements

Access reviews must verify:

- Business need
- Appropriate permissions
- Active employment status
- Segregation of duties compliance

10. Segregation of Duties (SoD)

Conflicting access rights shall be identified and mitigated.

Examples include:

- Approving and processing payments.
- Creating and approving user accounts.
- Managing and auditing security controls.

Management shall review exceptions and implement compensating controls where necessary.

11. Multi-Factor Authentication (MFA)

MFA must be enabled for:

- VPN access
- Microsoft 365 accounts
- Administrative accounts
- Financial systems
- Remote access systems
- Cloud platforms

Approved MFA Methods

- Microsoft Authenticator
- Hardware Tokens
- Push Notifications
- Biometric Verification

Target MFA Compliance: 100%

12. User Responsibilities

Employees

Employees are responsible for:

- Using only approved accounts.
- Protecting authentication credentials.
- Reporting unauthorized access.
- Following organizational security policies.

Managers

Managers are responsible for:

- Approving access requests.
- Reviewing user access.
- Validating business requirements.

Information Security Team

Responsible for:

- Monitoring compliance.
- Reviewing privileged accounts.
- Investigating violations.
- Maintaining access control standards.

13. Compliance Monitoring

Key Performance Indicators (KPIs)

Metric	Target
MFA Compliance	100%
Quarterly Access Reviews	100%
Privileged Account Reviews	100%
User Provisioning Accuracy	100%
Access Removal Within SLA	100%
Segregation of Duties Compliance	100%
Unauthorized Access Incidents	0

Sample Compliance Dashboard

Control	Result
MFA Compliance	100%
Access Reviews	98%
Privileged Reviews	100%
Access Removal SLA	100%
RBAC Compliance	97%

14. Policy Violations

Failure to comply with this policy may result in:

- Verbal warning
- Written warning
- Suspension of access privileges
- Disciplinary action
- Employment termination
- Legal action where applicable

All violations shall be investigated by the Information Security Team.

15. Policy Exceptions

Requests for policy exceptions must include:

- Business justification
- Risk assessment
- Management approval
- Information Security approval
- Compensating controls
- Defined expiration date

All approved exceptions shall be documented and reviewed annually.

16. Conclusion

ABC Healthcare Services is committed to implementing effective access control practices to protect information assets and business operations. Proper access management reduces organizational risk, supports compliance obligations, and ensures that access is granted only to authorized individuals based on business requirements.

17. References

- ISO/IEC 27001:2022
- NIST Cybersecurity Framework
- CIS Critical Security Controls
- Password Policy
- Information Security Governance Framework

18. Document Control

Field	Value
Document Owner	Information Security Manager
Document ID	ACP-001
Version	1.0
Classification	Internal
Review Frequency	Annual
Next Review Date	June 1, 2027